

TRIBUNAL DE CONTAS DO ESTADO DO RIO GRANDE DO NORTE

CARGO 12: AUDITOR DE CONTROLE EXTERNO – ESPECIALIDADE: TECNOLOGIA DA INFORMAÇÃO

Prova Discursiva – Estudo de caso

Aplicação: 11/4/2026

PADRÃO DE RESPOSTA DEFINITIVO

Os métodos de autenticação representam um dos principais mecanismos de controle de acesso em sistemas de informação, sendo fundamentais para garantir que apenas usuários devidamente autorizados possam acessar recursos sensíveis. Esses métodos podem ser classificados em fatores de autenticação, tais como posse (*tokens* e certificados digitais) e inerência (biometria), sendo recomendada a combinação entre eles para maior segurança. **Também podem ser descritos como: algo que o usuário sabe, algo que possui e algo que é.** Os *tokens*, por sua vez, constituem um fator de posse, podendo ser dispositivos físicos ou aplicações que geram códigos temporários (OTP – *one-time password*), frequentemente utilizados em autenticação de dois fatores. Esses mecanismos aumentam significativamente a segurança, pois exigem que o usuário tenha um elemento adicional além da senha. **Apresentam limitações como custos de implementação, dependência de dispositivo e risco de extravio ou interceptação.** Os certificados digitais, baseados em criptografia de chave pública, permitem a autenticação forte do usuário, além de garantir propriedades, como autenticidade, integridade e não repúdio das informações, sendo amplamente utilizados em ambientes governamentais e sistemas que exigem elevado grau de confiabilidade. **Dependem de infraestrutura de certificação (autoridade certificadora) e gestão de chaves, o que implica custos e complexidade operacional.** Já a biometria utiliza características físicas ou comportamentais do indivíduo, como impressão digital, reconhecimento facial ou de íris, oferecendo maior dificuldade de falsificação, embora traga desafios relacionados a privacidade, armazenamento seguro dos dados biométricos e possibilidade de falsos positivos ou negativos. **Pode demandar dispositivos específicos e custos de implantação e manutenção.**

No caso apresentado, a utilização exclusiva de autenticação baseada em senha demonstra uma falha crítica na política de segurança do sistema auditado. A ausência de mecanismos adicionais de proteção aliada à inexistência de políticas robustas de complexidade, expiração e gestão de credenciais aumenta significativamente a superfície de ataque. **Esse cenário favorece ataques, como força bruta, phishing e engenharia social.** O comprometimento de credenciais permite acessos indevidos, possibilitando a inserção ou alteração de dados de forma maliciosa, o que afeta diretamente a integridade e a confiabilidade das informações prestadas ao órgão de controle. Tal cenário evidencia violação dos princípios fundamentais da segurança da informação — confidencialidade, integridade e disponibilidade —, além de impactar a rastreabilidade e a responsabilização dos usuários, **compromete também a autenticidade e o não repúdio das ações realizadas**, elementos essenciais em sistemas de prestação de contas públicas.

Nesse contexto, a adoção de autenticação multifator (MFA) torna-se indispensável, pois combina dois ou mais fatores de autenticação, reduzindo significativamente o risco de acesso indevido, mesmo em caso de comprometimento de um dos fatores. Por exemplo, a combinação de senha com *token* ou certificado digital aumenta a robustez do processo de autenticação, enquanto a inclusão de biometria pode reforçar ainda mais a segurança. Em ambientes governamentais, como o sistema em tela, a implementação de MFA é especialmente relevante para garantir a autenticidade dos usuários, a integridade das informações e o não repúdio das ações realizadas, permitindo maior confiabilidade nos dados utilizados para fiscalização e tomada de decisão. Além disso, a adoção de mecanismos mais robustos de autenticação deve ser acompanhada por práticas de gestão de identidade e acesso (IAM), inclusive controle de privilégios, segregação de funções, auditoria de *logs* e monitoramento contínuo. **Inclui a aplicação do princípio do privilégio mínimo e modelos como RBAC ou ABAC.** A utilização de certificados digitais, por exemplo, permite vincular, de forma inequívoca, a identidade do usuário às operações realizadas, enquanto *tokens* e biometria dificultam ataques baseados em roubo de credenciais. Ainda, políticas de segurança alinhadas a normas como as ISO/IEC 27001 e 27002 contribuem para a implementação de controles adequados.

QUESITOS AVALIADOS

Quesito 2.1 – Métodos de autenticação

Quesito 2.1.1 – Tokens

Conceito 0 – Não discorreu sobre *tokens* ou o fez de forma totalmente equivocada.

Conceito 1 – Abordou corretamente apenas um dos aspectos (características, vantagens ou limitações) em relação a *tokens*.

Conceito 2 – Abordou corretamente apenas dois dos aspectos em relação a *tokens*.

Conceito 3 – Abordou corretamente os três aspectos em relação a *tokens*.

Quesito 2.1.2 – Certificados digitais

Conceito 0 – Não discorreu sobre certificados digitais ou o fez de forma totalmente equivocada.

Conceito 1 – Abordou corretamente apenas um dos aspectos (características, vantagens ou limitações) em relação a certificados digitais.

Conceito 2 – Abordou corretamente apenas dois dos aspectos em relação a certificados digitais.

Conceito 3 – Abordou corretamente os três aspectos em relação a certificados digitais.

Quesito 2.1.3 – Biometria

Conceito 0 – Não discorreu sobre biometria ou o fez de forma totalmente equivocada.

Conceito 1 – Abordou corretamente apenas um dos aspectos (características, vantagens ou limitações) em relação à biometria.

Conceito 2 – Abordou corretamente apenas dois dos aspectos em relação à biometria.

Conceito 3 – Abordou corretamente os três aspectos em relação à biometria.

Quesito 2.2 – Riscos associados ao uso exclusivo de autenticação baseada em senhas

Conceito 0 – Não discorreu sobre os riscos associados ao uso exclusivo de autenticação baseada em senhas ou o fez de forma totalmente equivocada.

Conceito 1 – Analisou corretamente os riscos associados ao uso exclusivo de autenticação baseada em senhas, mas não os relacionou com o caso apresentado nem com princípios de segurança da informação.

Conceito 2 – Analisou corretamente os riscos associados ao uso exclusivo de autenticação baseada em senhas, mas os relacionou apenas com o caso apresentado ou apenas com princípios de segurança da informação.

Conceito 3 – Analisou corretamente os riscos associados ao uso exclusivo de autenticação baseada em senhas e os relacionou tanto com o caso apresentado quanto com princípios de segurança da informação.

Quesito 2.3 – Importância da autenticação multifator (MFA) e de mecanismos mais robustos de autenticação

Conceito 0 – Não abordou o quesito ou o fez de forma totalmente equivocada.

Conceito 1 – Abordou o quesito de forma superficial, sem desenvolvimento.

Conceito 2 – Desenvolveu o quesito de forma parcialmente inconsistente ou desconectada da situação apresentada.

Conceito 3 – Desenvolveu o quesito de forma correta e contextualizada com a situação apresentada.